

Master Thesis

Detection and Mitigation of Rollback Attacks in Automotive Over-The-Air Updates

Supervisors:

Prof. Dr.-Ing. Rahamatullah Khondoker (THM)

Mr. Mario Hoffmann and Mr. Vatsal Patel (ARRK GmbH)

Tarush Gupta

Tarush Gupta

Bachelors of Technology - Mechatronics
Manipal University Jaipur, India 2018-2022

Master of Science - Computer Control Communication Engineering
Technische Hochschule Mittelhessen 2022-2024

Work Experience:

lvlAlpha Pvt. Ltd. - Defence Startup (August 2020 - June 2022)

- Wearable Devices for trauma monitoring
- Covid-19 Isolation Pod
- Automatic Waffle Vending Machine

Werkstudent - THM (April 2023 - September 2023)

- CrossCore Embedded Studio
- ADSP SC589 - Audio Processing module
- Fast Fourier Transform

Publications:

- **IoT based Smart City Applications: Infrastructure, Research and Development**
- **Strengthening Automotive Cybersecurity: A Comparative Analysis of ISO/SAE 21434-Compliant Automatic Collision Notification (ACN) Systems**

Table of Contents

Overview

Workflow

Cyclic Diagram

Development of Prototype

Implementation of Prototype

Dual Boot Architecture

ECU and TCU Simulation

Reference Architecture SWUpdate

TARA

Security Goals and Concept

Detection and Mitigation Algorithms

Overview

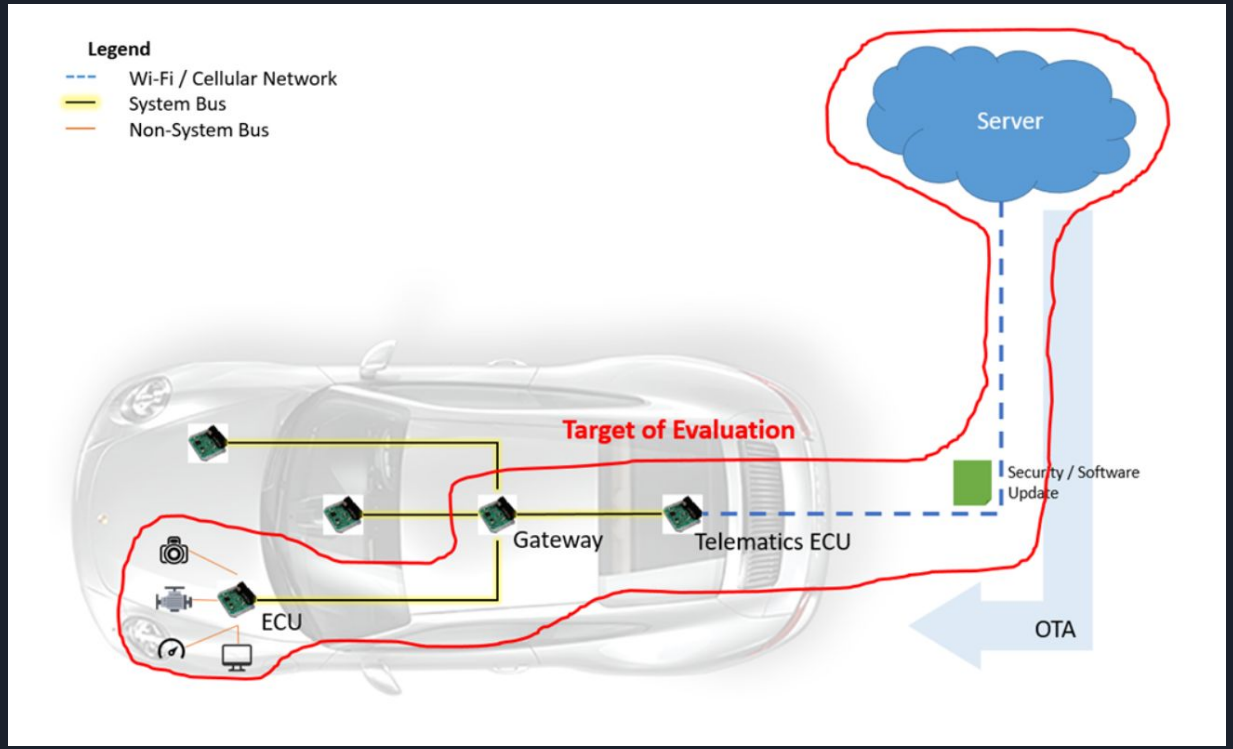
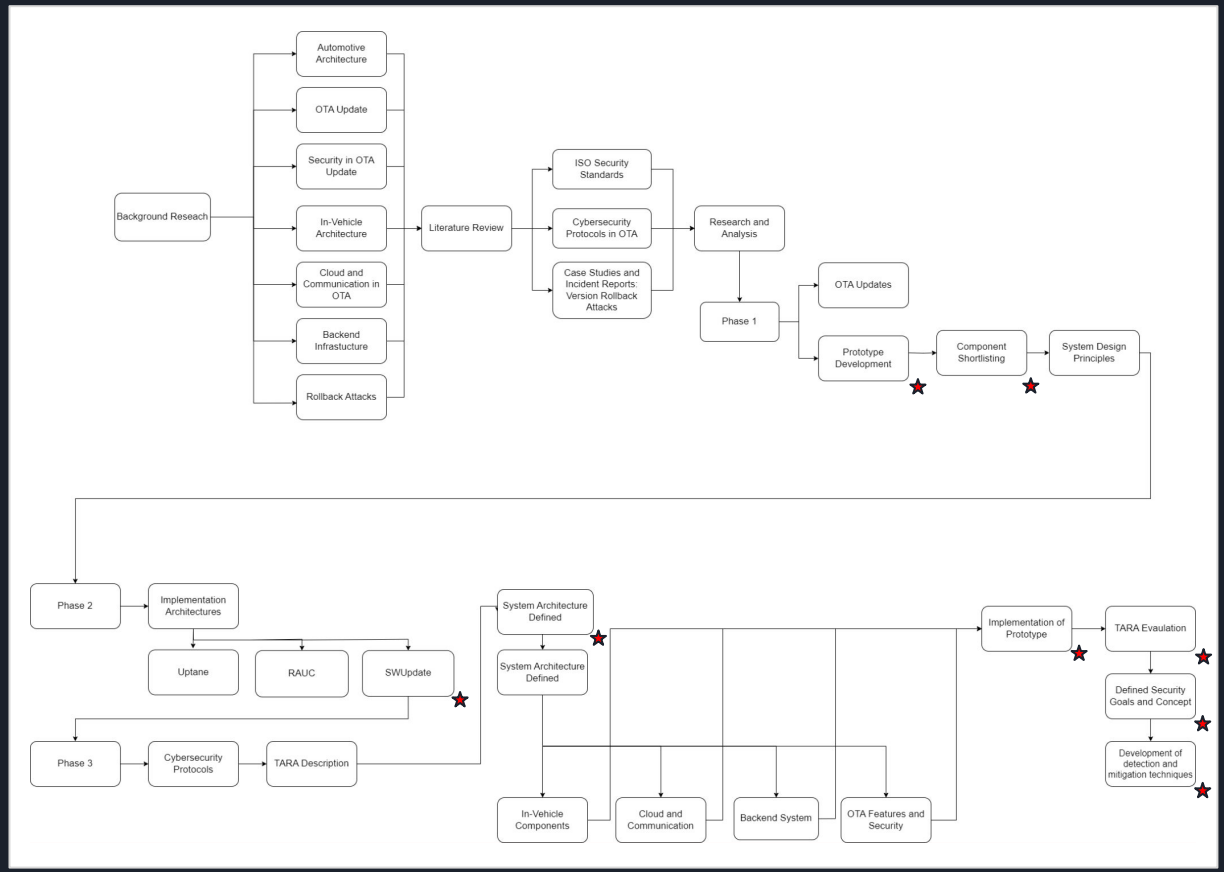


Fig: Automotive OTA Update Evaluation

WorkFlow


Background Reseach
Automotive Architecture
OTA Update
Security in OTA Update
In-Vehicle Architecture
Cloud and Communication in OTA
Backend Infrastucture
Rollback Attacks
Literature Review
ISO Security Standards
Cybersecurity Protocols in OTA
Case Studies and Incident Reports: Version Rollback Attacks
Research and Analysis
Phase 1
OTA Updates
Prototype Development
Component Shortlisting
System Design Principles
Phase 2
Implementation Architectures
Uptane
RAUC
SWUpdate
Phase 3
Cybersecurity Protocols
TARA Description
System Architecture Defined
System Architecture Defined
In-Vehicle Components
Cloud and Communication
Backend System
OTA Features and Security
Implementation of Prototype
TARA Evaulation
Defined Security Goals and Concept
Development of detection and mitigation techniques

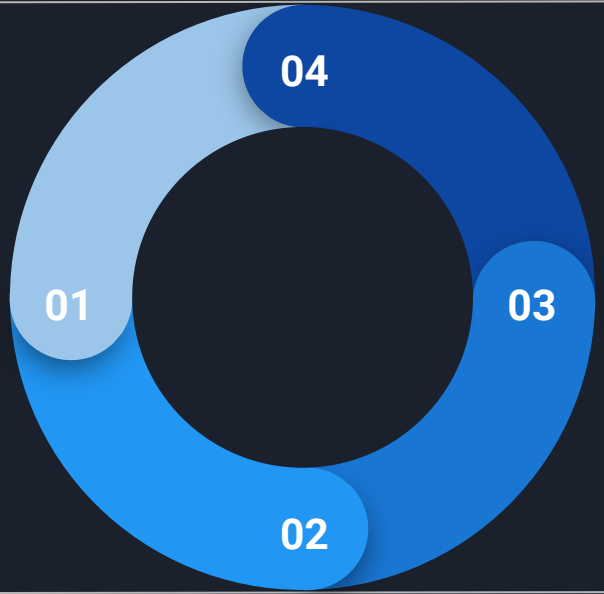
Cycle diagram

Prototype

Research, development and implementation of the prototype

TARA

Threat Modelling on the basis of Clause 15. ISO21434 (TARA)



Mitigation Algorithms

As per the Security Algorithms, some detection and mitigation techniques are proposed

Security Goals

Based on the results of TARA, Security goals and security concept are defined

Development of the prototype

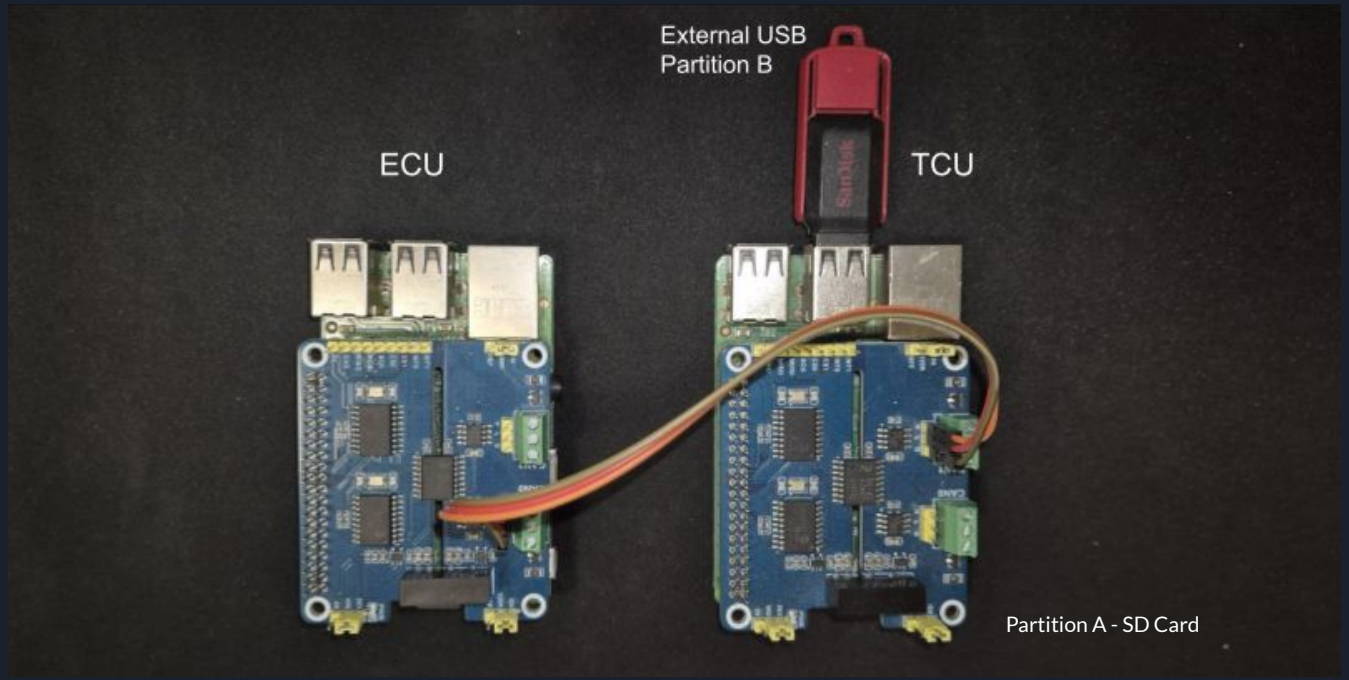


Fig: Raspberry Pi based Robust Automotive Update Prototype

Implementation of the prototype

01 Raspberry Pi 3B+ (for ARRK Prototype - RPi 5)s are chosen for simulating the ECU and the TCU with a CAN Shield and a LCD Display on the Raspberry Pi for the visual head unit like display.

02 The features of Raspberry Pi are used: Wi-Fi for communication to the server using internet, SPI to integrate the CAN Shield, 7’ Inch LCD Panel for display and Tkinter for GUI Panel for TCU and ECU simulation.

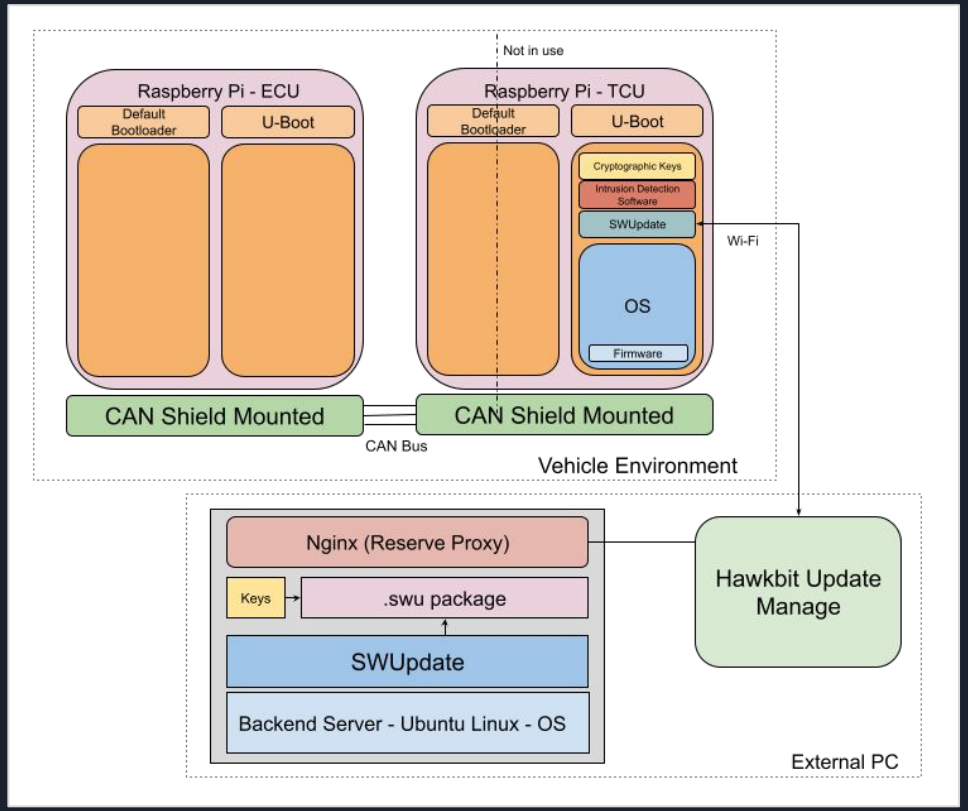
03 Integration with SWUpdate for OTA Update Implementation, Suricata as the intrusion detection system, NGINX used as reverse proxy, Hawkbit as the Update manager.

04 A/B Type robust update architecture: use of external bootloader, another memory space that can be used as the other memory bank.

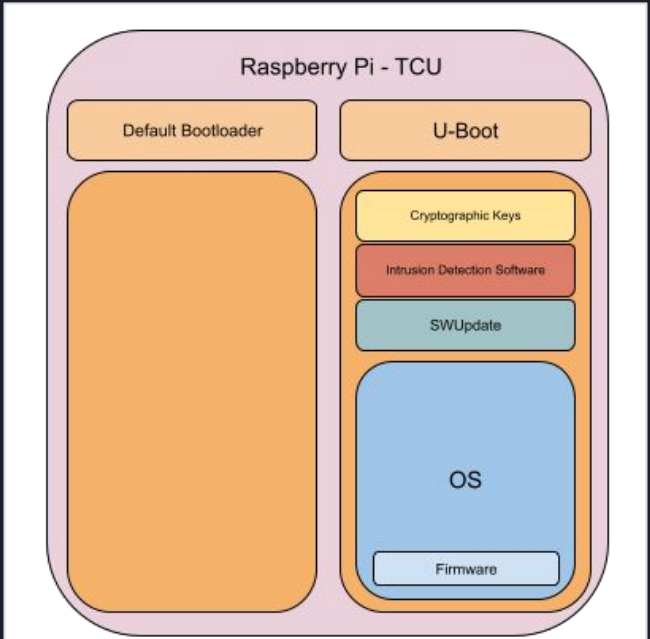
List of Components:

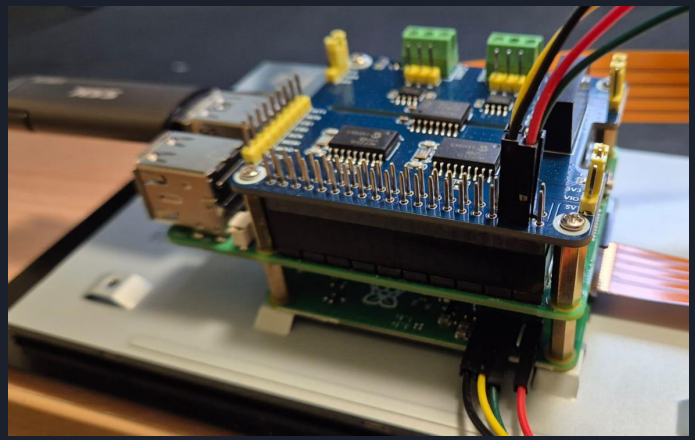
- Raspberry 5 - ECU
- Raspberry 5 - TCU
- WB CAN Shields
- Display unit - TCU
- Wi-Fi enabled
- Use of SPI for CAN Shield
- Tkinter GUI HU Panel
- SWUpdate - OTA Architecture
- NGINX - reverse proxy
- Hawkbit - Update Manager
- Suricata as the IDS
- U-boot bootloader with dual bootable memory.

Prototype Architecture

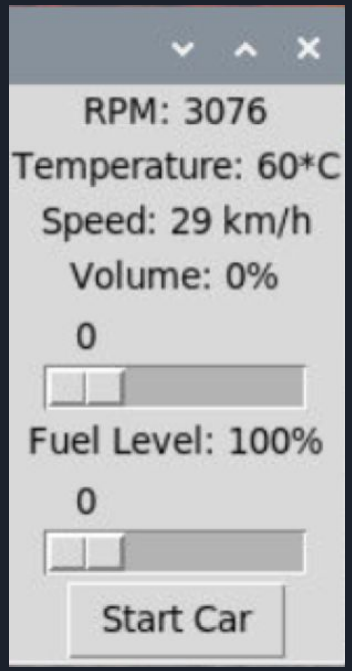


Dual Boot Architecture

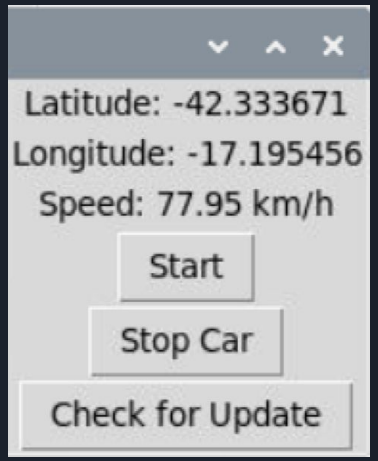




Simulation Panel for ECU and TCU

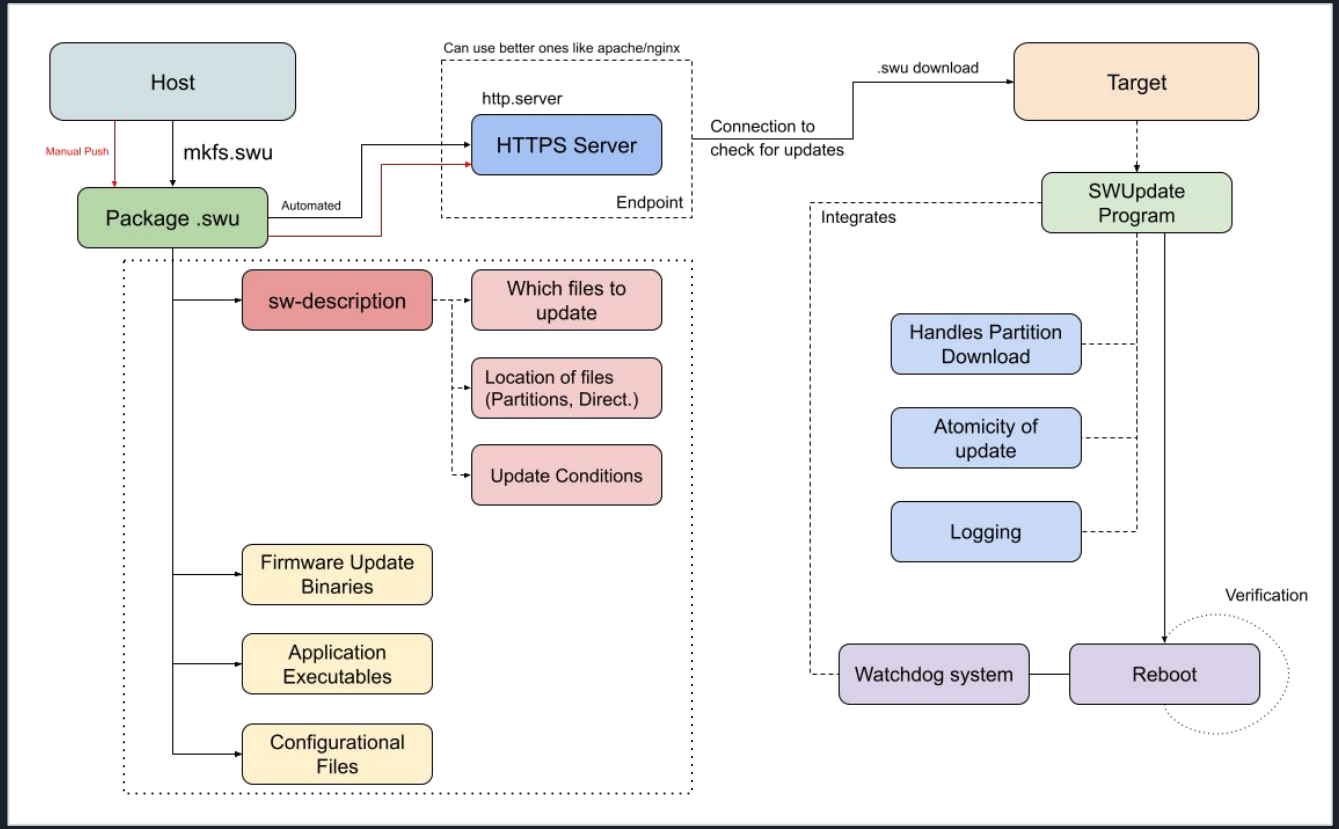


ECU Simulation



TCU Simulation

SWUpdate - Reference Architecture



TARA - Threat Analysis and Risk Assessment

A Threat Analysis of the developed prototype is done keeping in mind the Version Rollback attacks, and attacks that can lead to them example Man-in-the-middle attack.

The Threat modelling is done on the basis of the Clause 15. - TARA of ISO21434.



Asset Identification

Threat Scenario Identification

Impact Rating

Attack Path Analysis

Attack feasibility rating

Risk value determination

Risk treatment decision

On the basis of the above, security goals and security concepts, three new algorithms are defined, that aim detection and mitigation of Version Rollback Attacks

Asset Identification

The assets chosen for the TARA Analysis are as follows:

High Level Assets

- ECU / Engine Control Unit
- TCU / Telematics Control Unit
- Wi-Fi
- Update Server
- Backend System

More in-detailed Assets

- CAN
- SWUpdate
- Private and Public Keys

In this case, mainly the high level Assets are identified and fewer more in-detailed Assets for the defined scope and time limitations for the Thesis.

Private Signing keys, public verification keys and SWUpdate are taken as examples for describing the TARA Methodology ahead.

Asset Identification

Component	Description	Cybersecurity Properties	Damage Scenario
SWUpdate	System responsible for securely updating software on vehicles and embedded devices.	Confidentiality, Integrity, Availability	Tampering, unauthorized access, DoS attacks, failed update verification, and man-in-the-middle attacks.
Cryptographic Keys	Keys used for signing and verifying software updates.		Forged signatures, unauthorized updates, and rollback attacks.
(a) Private Signing Keys	Signs update packages to ensure authenticity.	Confidentiality, Integrity, Availability	Leaks lead to unauthorized updates, rollback attacks, and system takeovers.
(b) Public Verification Keys	Verifies signatures on updates to confirm they are from a trusted source.	Integrity, Availability	Compromise leads to acceptance of malicious updates and breakdown of trust.

Threat scenario identification

Asset	S	T	R	I	D	E
SWUpdate	✔	✔	✔	✔	✔	✔
Private Signing Keys	✔	✔		✔		
Public Verification Keys	✔	✔				

S: Spoofing, T: Tampering, R: Repudiation, I: Information Disclosure, D: DoS, E: Elevation of Privilege

Impact Rating

Threat Scenario	Impact Rating	SWUpdate	Private Signing Keys	Public Verification Keys
Spoofing	S	Severe	Severe	Severe
	F	Major	Severe	Major
	O	Severe	Severe	Severe
	P	Moderate	Major	Moderate
Tampering	S	Severe	Severe	Severe
	F	Major	Severe	Major
	O	Severe	Severe	Severe
	P	Major	Severe	Major
Repudiation	S	Moderate	N/A	N/A
	F	Major	N/A	N/A
	O	Moderate	N/A	N/A
	P	Major	N/A	N/A

Impact Rating

Threat Scenario	Impact Rating	SWUpdate	Private Signing Keys	Public Verification Keys
Information Disclosure	S	Major	Severe	N/A
	F	Severe	Severe	N/A
	O	Moderate	Major	N/A
	P	Severe	Severe	N/A
Denial of Service	S	Severe	N/A	N/A
	F	Major	N/A	N/A
	O	Severe	N/A	N/A
	P	Negligible	N/A	N/A
Elevation of Privilege	S	Severe	N/A	N/A
	F	Major	N/A	N/A
	O	Major	N/A	N/A
	P	Severe	N/A	N/A

Attack Path Analysis

1. SWUpdate

- Unauthorized Access due to compromised credentials:
  - Brute Force
  - Leaked Credentials: Inside attack/ social engineering
  - Session Hijacking: Man-in-the-middle attack

- Weak network can lead to compromised delivery pipeline
  - DNS Spoofing/Poisoning: Network Compromise
  - Mid transit tampering: Man-in-the middle attack / unencrypted network
  - Network Sniffing: Network Compromise

- Exploitation of update pipeline using a backdoor
  - Pre-installed Backdoors: Can be implemented during the build process
  - Supply Chain Attacks: If third party applications are compromised/vendors
  - Tampering of an update: Update tampering during the building of the update package or transmission

Attack Path Analysis

2. Private Signing Keys

- Theft , leakage or loss:
  - Leaked Credentials: Inside Attack / social engineering
  - Leaked from the manufacturers

- Compromised update distribution system
  - Access to the infrastructure: Insider attack/unauthorized access
  - Tampering of update packages and signing the update package

- Supply Chain Attack:
  - Attack on Third-Party Component Supplier
  - Supplier’s Malicious Updates are Distributed to Manufacturer

Attack Path Analysis

3. Public Verification Keys

- Public Key Substitution or Spoofing Attack:
  - Attacker compromises the public key distribution and replaces public verification key with malicious key
  - Compromised public key from attackers private key - leading to verified malicious installation
  - Man-in-the-middle while transmission

- Exploitation of Vehicle Firmware with Public Key Tampering
  - Physical Access to the ECUs
  - Tampering of update packages and signing the update package

- Supply Chain Attack:
  - Attack on Third-Party Component Supplier
  - Supplier’s Malicious Updates are Distributed to Manufacturer

- Compromise of Certificate Authority (CA) for Public Keys
  - Attack on Certificate Authority (CA)
  - Issuance of Fake Certificates

Attack Feasibility Rating

Cryptographic Keys/SWUpdate	Attack Path	Attack Feasibility Rating	Specialist Expertise	Knowledge of this Item	Window of Opportunity	Equipment	Rating
Private Signing Keys	Theft	≤ 1 month	Expert	Confidential Information	Difficult	Specialized	Very Low
	Update Distribution system	≤ 1 month	Multiple Experts	Strictly Confidential Information	Difficult	Bespoke	Very Low
	Supply Chain Attack	≤ 1 month	Multiple Experts	Strictly Confidential Information	Difficult	Bespoke	Very Low
Public Verification Keys	Key Substitution	≤ 1 month	Proficient	Confidential Information	Moderate	Specialized	Very Low
	Physical	≤ 1 day	Expert	Strictly Confidential Information	Difficult	Specialized	Very Low
	Supply Chain Attack	≤ 1 month	Multiple Experts	Strictly Confidential Information	Difficult	Bespoke	Very Low
	Compromised CAs	≤ 1 month	Multiple Experts	Confidential Information	Difficult	Bespoke	Low
	Theft	≤ 1 month	Expert	Confidential Information	Difficult	Specialized	Very Low
SWUpdate	Unauthorized Access	≤ 1 month	Expert	Confidential Information	Difficult	Bespoke	Very Low
	Compromise of Delivery System Pipeline	≤ 1 month	Expert	Confidential Information	Moderate	Bespoke	Very Low
	Backdoor Injection	≤ 1 month	Expert	Confidential Information	Moderate	Specialized	Very Low

Risk Value Determination

Impact \ Feasibility	Negligible	Moderate	Major	Severe
Very Low	Low	Low	Low	Medium
Low	Low	Medium	Medium	Medium
Medium	Low	Medium	High	High
High	Medium	High	High	Critical

On the basis of the above risk assessment matrix, the risk value determination of the assets is done in context to their threat scenarios

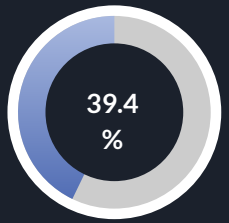
Risk Value Determination

Assets	Threat Scenario	Impact Rating	Feasibility Rating	Risk Value
SWUpdate	Spoofing	Major	Very Low	Low
	Tampering	Severe	Very Low	Medium
	Repudiation	Moderate	Very Low	Low
	Information Disclosure	Severe	Very Low	Medium
	DoS	Major	Very Low	Low
	Elevation of Privilege	Severe	Very Low	Medium
Private Signing Keys	Spoofing	Severe	Low	Medium
	Tampering	Severe	Low	Medium
	Information Disclosure	Severe	Low	Medium
Public Verification Keys	Spoofing	Major	Low	Medium
	Tampering	Severe	Medium	Medium

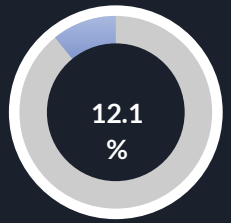
Risk Treatment Decision

Out of the 33 different Threat possible Threat Scenarios based on STRIDE in ISO 21434 TARA. The following were the decision percentages.

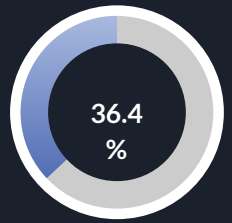
Risk Reduction for High and Medium-High Risks, Risk Avoidance and Transfer are for some Medium-high and Medium risks and for Medium-low and low level threats, Risks are retained



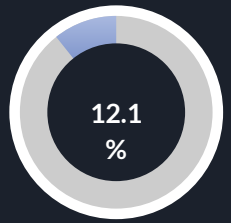
Risk Reduction



Risk Transfer



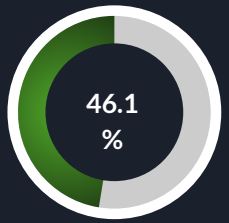
Risk Avoidance



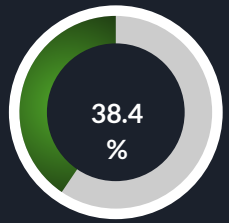
Risk Retention

Risk Reduction

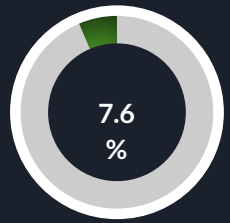
Out of the 39.4%, about 85% cases were in the case of spoofing and tampering of the components, which denotes a high level authorization and update package verification vulnerability. To mitigate the chances of tampering and spoofing, on context of the detection and mitigation of Version Rollback Attacks, following are the security goals defined



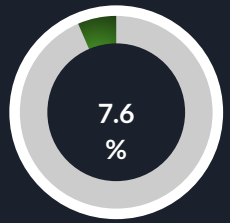
Tampering



Spoofing



Information Disclosure



Elevation of Privilege

Security Goals

The above, TARA, results are further analysed and 3 security goals are defined on the basis of it.

- The goal is to mitigate risks of Man-in-the-Middle attacks that enable version rollback and other OTA update vulnerabilities. The TARA identified critical risks from accepting outdated, vulnerable software and emphasized the need for strong validation to ensure update integrity and authenticity.

- The goal is to ensure accurate application of incremental OTA updates, preventing misidentification or false success reports. This is achieved by securing the integrity and authenticity of each update using serial numbers and hash values to prevent tampering and false validation.

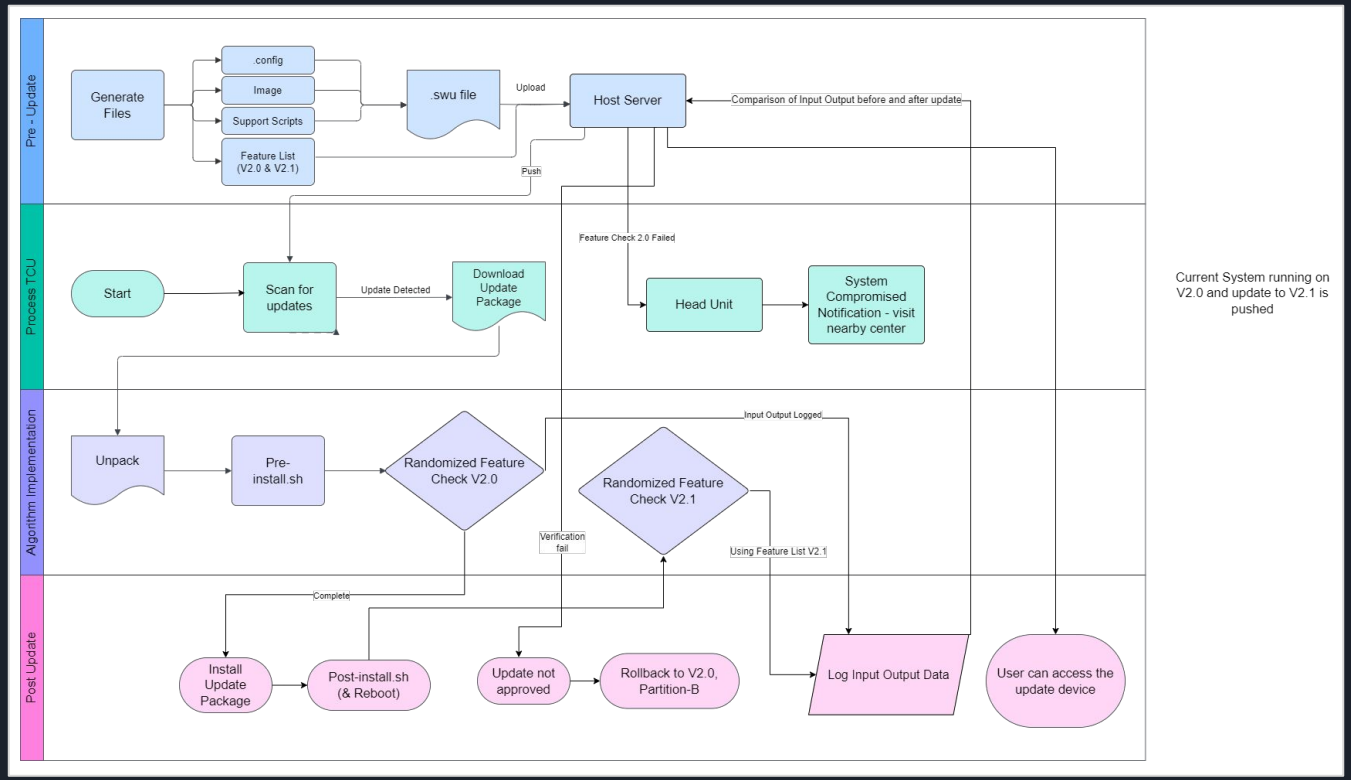
- The goal is to develop an algorithm that authenticates users with the server before major tasks, preventing unauthorized access and spoofing. The server and user application should sync with a global time server using rolling passwords.

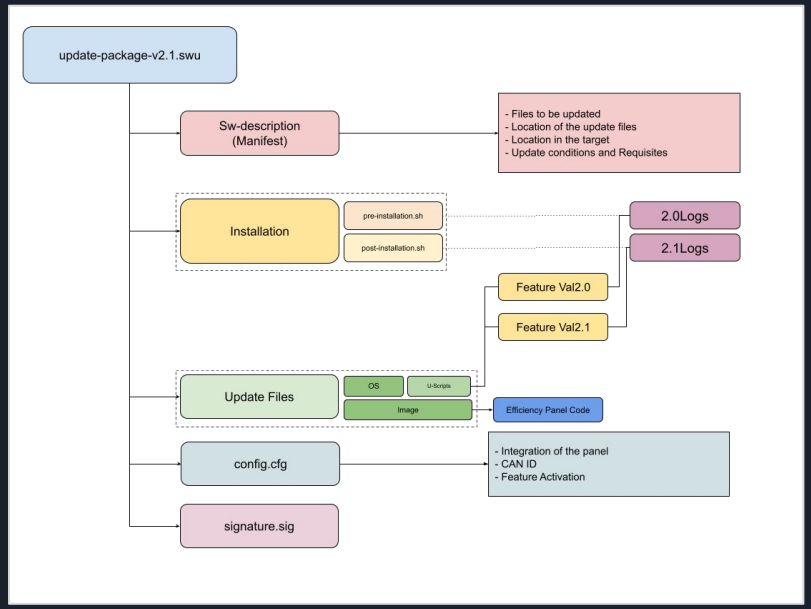
Security Concept

The security concept for the OTA update system should ideally integrate multiple layers of defense to protect against various attack vectors identified during the threat analysis and TARA. The concept should focus on preventing unauthorized access, tampering, and rollback attacks while ensuring the integrity and authenticity of updates. The design should incorporate strong authentication mechanisms, cryptographic validations, and secure communication protocols.

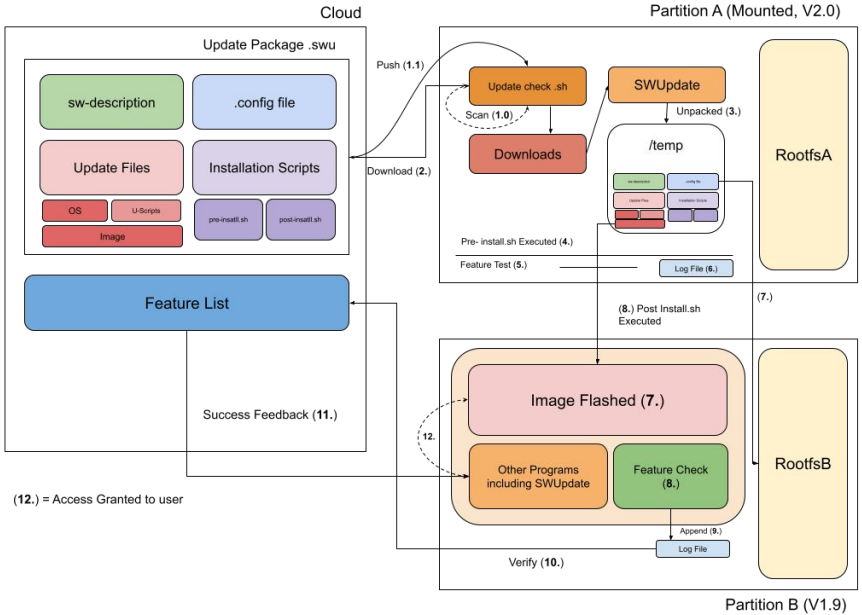
The Security Goals and Concept are important for proposing and further defining, detection and mitigation techniques and strategies.

Algorithm 1: Feature Validation & Update Verification





Update Package Structure

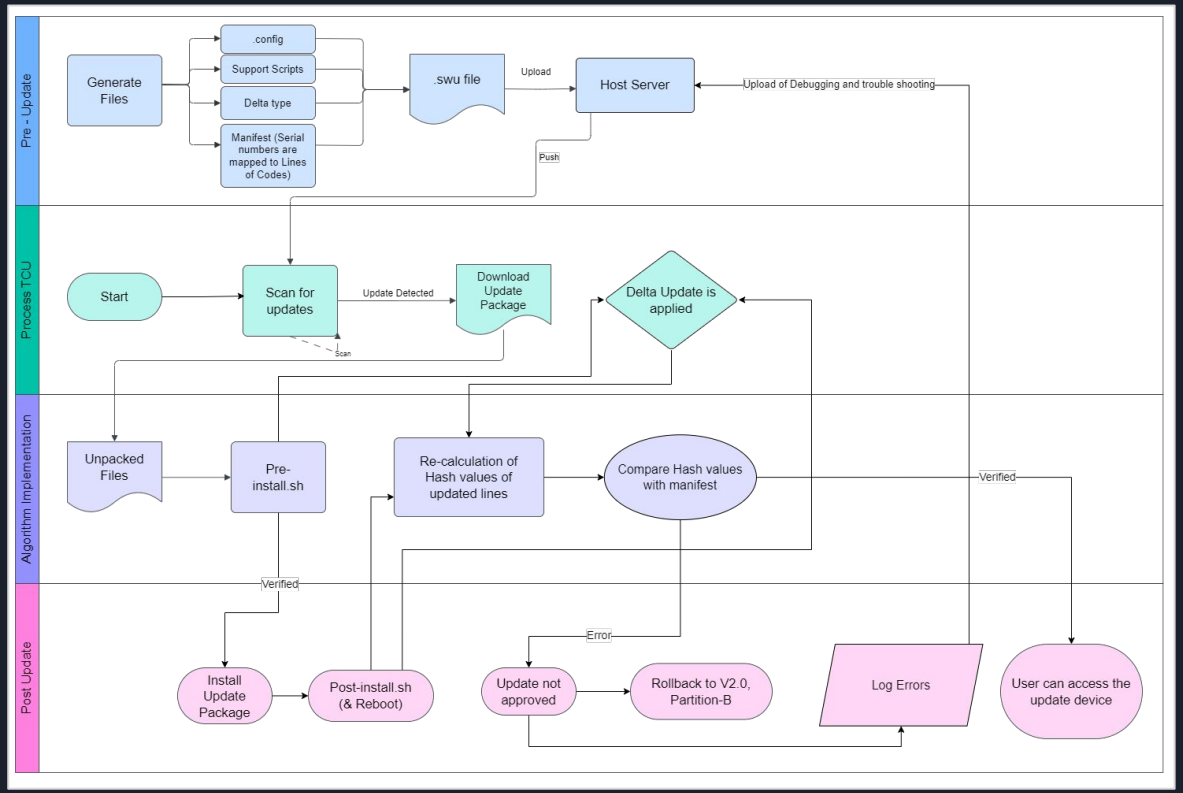


Update Procedure and Installation procedure

State of the Art Comparison

Automaker	Pre-Update Checks	Update Process	Post-Update Diagnostics
Tesla	Battery level, network connectivity	Background download and installation, integration of new features	System integrity checks, functionality validation
Volkswagen	Simulation environments, Hardware-in-the-loop (HIL) setups	Validation of Advanced Driver Assistance Systems (ADAS) and Autonomous Vehicle (AV) systems under various conditions	Comprehensive diagnostics to ensure correct functionality
Toyota	Advanced diagnostic algorithms, anomaly detection	Checks on sensors, actuators, and control units	Comprehensive performance checks before, during, and after updates
General Motors	Extensive system checks for compatibility	Background update process, VIP and Ultifi platforms	Pre-update and post-update validation tests
BMW	Advanced diagnostic algorithms	Real-time diagnostics during update, pre-update checks	Post-update validation to verify new features and functions

Algorithm 2: Serialising Update script lines/functions



Description

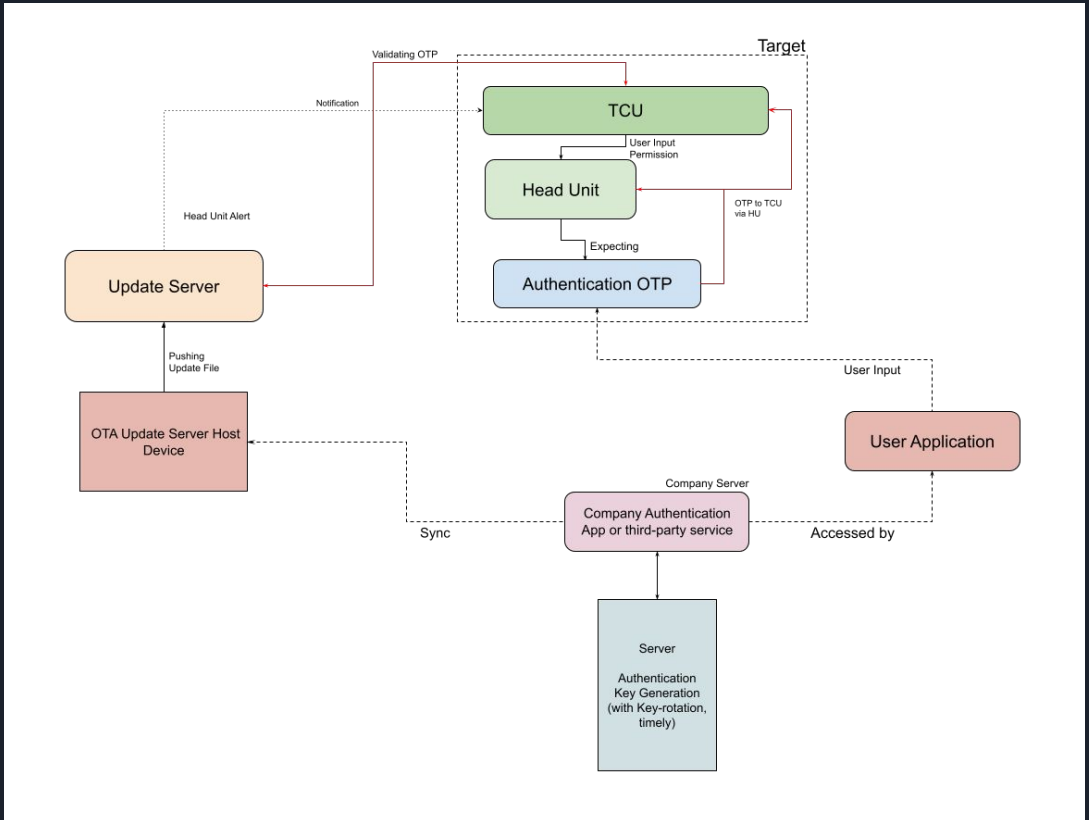
Serial Number	New Code Line
001	new_line1
002	new_line2
003	new_line3

- Manifest should have Serial number mapping
- The hash of each line of the script or executable is mapped
- Post update, the hashed are recalculated in the updated device
- The serial numbers are then compared against the hashes from the manifest

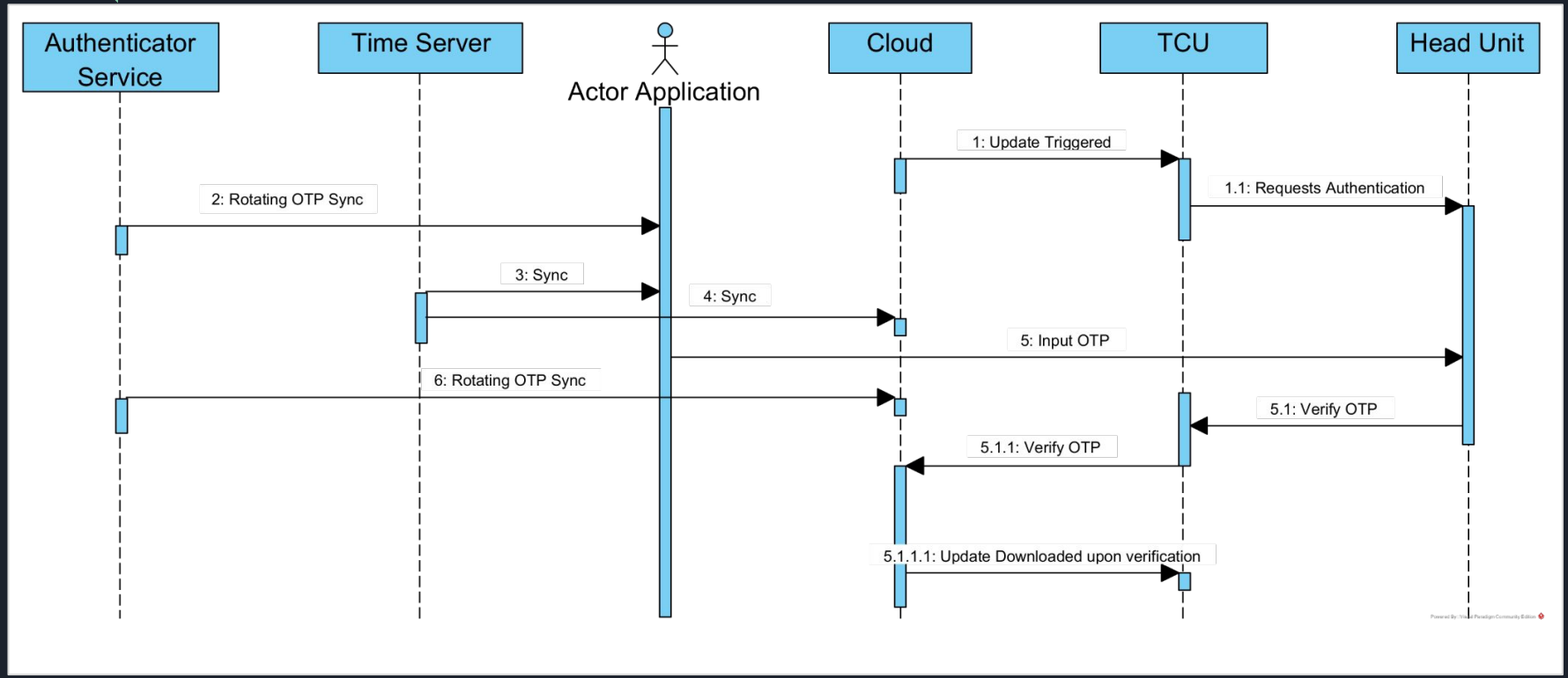
State of the Art

Category	Tool Name	Description	ECU Compatible
Static Code Analysis	Polyspace	Analyzes runtime errors like division by zero and buffer overflows.	Yes
	QAC	Checks compliance for C/C++ code, focusing on MISRA standards.	Yes
	PC-lint/FlexeLint	Detects bugs, coding violations, and complexity issues in C/C++ code.	Yes
	Klocwork	Identifies security vulnerabilities, safety issues, and compliance with standards.	Yes
Model-Based Development	Simulink Code Inspector	Verifies generated code against model behavior.	Yes
	TargetLink	Generates code from MATLAB/Simulink models with verification and testing.	Yes
Automated Testing	VectorCAST	Tests embedded software, including unit, integration, and system testing.	Yes
	Parasoft C/C++test	Static analysis and testing for C/C++ code with unit testing and code coverage.	Yes
Code Coverage	GCOV	Analyzes code coverage using GCC.	Configurable
	LDRA Testbed	Provides static and dynamic code analysis with detailed code coverage reporting.	Yes
IDE Plugins	IAR, Keil IDE Plugins	Code analysis and checking within automotive development environments.	Yes
Scripting Tools	Pylint	Checks code quality and adherence to standards in Python scripts.	No
	ShellCheck	Analyzes shell scripts for syntax and style errors.	Configurable

Algorithm 3 - Rolling OTP Authentication



Sequence Diagram



State of the Art

OEM/Company	Technology/System Details
Bosch	Secure Gateway (SGW) uses AutoAuth for secure diagnostics/updates. No explicit mention of rolling OTP.
Remote Keyless Entry	Rolling Code System generates new codes per use, preventing replay attacks. Similar to rolling OTP.
Mender	Open Source OTA Platform focuses on secure OTA with phased rollouts and custom security. Could integrate OTP.
Uptane	OTA Security Framework secures OTA with multi-layer defenses. OTP not mentioned but possible.
Renesas	Compliance with ISO 24089 and UNECE WP.29 R156. Follows regulations for secure OTA; could integrate OTP for additional security.
BMW, Ford, Volkswagen, Volvo	Secure OTA Systems extensively use OTA for system updates. Follow similar protocols to Tesla, but exact mechanisms (e.g., rolling OTPs) not publicly detailed.

Thank you!

I’d be happy to answer questions if any!